

The ABCs of IOCs

Apa itu Indicator of Compromise (IOC)

Terdapat beberapa definisi dari Indicator of Compromise (IOC), Microsoft mendefinisikannya sebagai bukti bahwa seseorang telah menyusup ke dalam jaringan atau *endpoint* sebuah organisasi. Sementara Cisco menyebutnya sebagai petunjuk bahwa sebuah jaringan atau *endpoint* sudah disusupi. Gradigo, Will pada konferensi RSA 2012¹ mendefinisikan IOC² sebagai artifak pada network atau *operating system*, yang dengan kepercayaan tinggi mengindikasikan intrusi. Secara umum pengertian dari IOC tidak jauh berbeda, dengan benang merah yang bisa kita tarik dari beberapa pengertian tersebut adalah, IOC merupakan sebuah bukti bahwa terjadi intrusi.

Berangkat dari definisi tersebut, beberapa contoh dari IOC yang umum digunakan antara lain *IP address*, *hash values* dari sebuah *file*, ataupun *domain name*. Biasanya dalam sebuah insiden, IOC ini memiliki keterkaitan dengan jalannya intrusi: *IP address* mungkin digunakan oleh *threat actor*, *hash* dari sebuah *file* yang digunakan sebagai *tool* dari *adversary*, atau *domain name* yang merupakan tujuan *adversary* melakukan koneksi *command and control*.

Akhirnya, tujuan dari berbagai IOC ini adalah bagi *defender* untuk melakukan *detect and respond*. Mendeteksi dan merespon *adversary* dengan menggunakan IOC terkait, sehingga *adversary* tidak dapat menggunakan *asset* yang terkait dengan IOC tertentu. Sebagai contoh, apabila kita sudah memiliki IOC berupa *hash values* dari sebuah *file* yang dipakai *adversary*, maka apabila *adversary* tidak mengubah *hash values* dari *file* tersebut ketika menggunakannya, *defender* akan mendeteksi dan merespon *adversary*.

Berbagai IOC

Terdapat berbagai cara untuk mengkategorikan IOC, salah satu yang umum digunakan adalah dari *Lockheed Martin*, yang membagi jenis IOC menjadi tiga jenis, yaitu:

¹ <https://web.archive.org/web/20170914034202/https://blogs.rsa.com/understanding-indicators-of-compromise-ioc-part-i/>

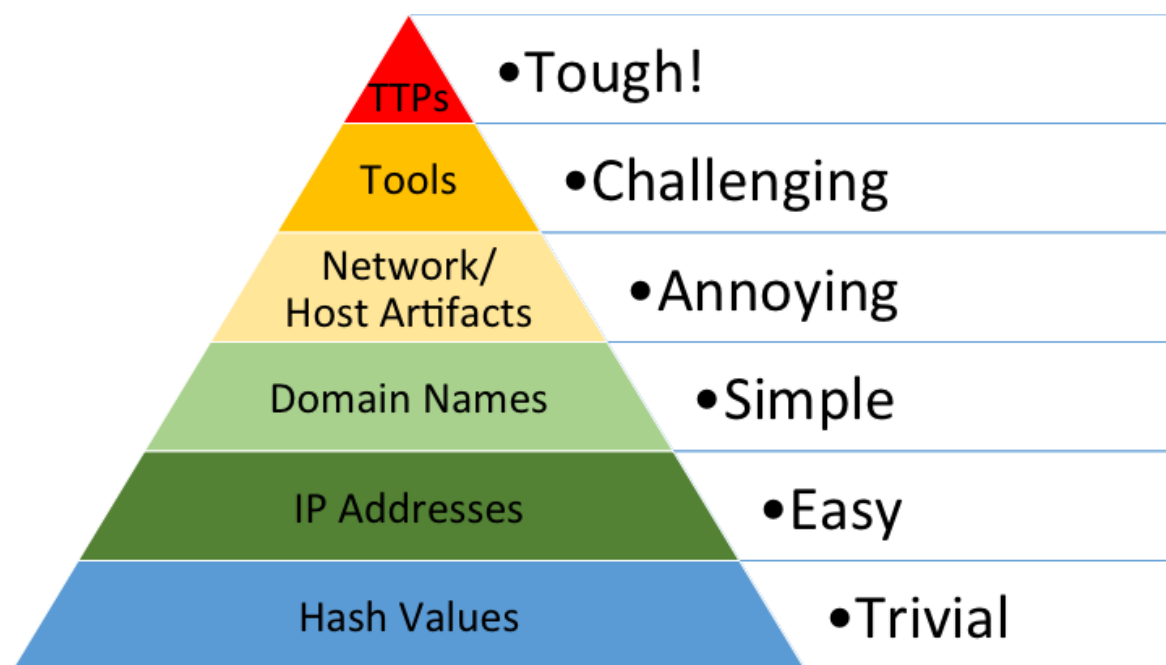
² tertarik tentang sejarah penggunaan terminology IOC? baca *blog post* ini: <https://taosecurity.blogspot.com/2018/11/the-origin-of-term-indicators-of.html>

Atomic IoCs disebut atomic karena IOC ini sudah tidak dapat dibagi menjadi lebih kecil lagi, diturunkan dari konsep atom pada ilmu sains, contoh: *IP addresses, email addresses, hostnames, process names, file names, text strings, domain names*.

Computed IoCs adalah hasil komputasi atas data dari sebuah insiden, contohnya *hash values, regular expressions*.

Behavioral IoCs adalah rangkaian atomic dan computed IOC's digunakan dalam sebuah insiden. Contohnya *adversary* mengakses dengan menggunakan *backdoor* dengan *[hash values]* dari sebuah alamat *[IP address]*. Secara umum IOC ini juga sering disebut dengan *tactics, techniques, dan procedures (TTP)*.

Tentu saja tidak semua IOC dilahirkan sederajat dan terdapat beberapa kategori IOC. Sesuai dengan tujuan yang disampaikan sebelumnya, *defender* dapat menilai seberapa efisien sebuah IOC untuk memaksa *adversary* tidak menggunakan *asset* terkait, biasanya dengan menggunakan “*pyramid of pain*”.



Secara sederhana, diagram ini memperlihatkan hubungan antara indikator dan seberapa “sakit” yang akan dirasakan oleh *adversary* apabila indikator tersebut diketahui. Kembali ke contoh awal, apabila *defender* mengetahui *hash values*³ dari sebuah *file*, maka *adversary* hanya

³ <https://detect-respond.blogspot.com/2022/04/stop-using-hashes-for-detection-and.html>

perlu mengubah *hash* tersebut, yang terbilang lebih mudah dilakukan dibanding mengubah sebuah *domain* C2.

Cloud IOC

Meningkatnya penggunaan *cloud computing* memperkenalkan berbagai persoalan keamanan baru, antara lain meluasnya perimeter keamanan, menciptakan titik-titik rentan baru seperti API, konfigurasi cloud yang salah, dan kerentanan dalam layanan cloud. Hal ini memicu munculnya IOC baru yang terkait dengan aktivitas mencurigakan di lingkungan cloud.

Tidak ada perbedaan definisi atomic dan behavioral IOC pada cloud, namun kita akan membahas khusus beberapa contoh *atomic* dan *behaviour* IOC spesifik pada *cloud*, untuk mendapatkan gambaran lebih terang.

Atomic IOC in the Cloud

Berbagai contoh atomic IOC pada cloud environment:

AWS IAM names, contohnya pada laporan Datadog Security Labs⁴ kita dapat melihat AWS IAM names *EmperorsToolsShops32*. AWS IAM names ini digunakan sebagai sarana *persistence* dan memiliki relasi dengan “The Emperor Tools toolkit”. Laporan dari Datadog tersebut memuat beberapa AWS IAM names lain yang kerap ditemui sebagai IOC. Contoh lain adalah **AWS security group name**, contohnya “Java_Ghost” yang juga terlihat digunakan sebagai sarana *persistence*⁵. IOC terkait *persistence* lain yang diamati pada laporan yang sama yaitu penggunaan “*temp_key_pair*” dan “*xg1*” sebagai **EC2 keypair name**. Wiz.io mengelompokkan kedua atomic IOC ini ke dalam **Cloud user metadata** dan **Credential metadata**.

Atomic IOC lain contohnya adalah **cloud subscription metadata**. Invictus-IR⁷ membahas IOC berupa dua AWS account ID (265857590823 dan 671050157472) yang digunakan untuk *persistence*. Dua account ID tersebut merupakan milik *attacker*. Kemudian *attacker* membuat

⁴<https://securitylabs.datadoghq.com/articles/following-attackers-trail-in-aws-methodology-findings-in-the-wild/#most-common-enumeration-techniques>

⁵<https://securitylabs.datadoghq.com/articles/following-attackers-trail-in-aws-methodology-findings-in-the-wild/#most-common-enumeration-techniques>

⁶ https://www.reddit.com/r/aws/comments/umkjl/ses_email_service_ive_been_hacked/

⁷ <https://www.invictus-ir.com/news/the-curious-case-of-dangerdev-protonmail-me>

role pada *compromised AWS account* yang dimiliki korban dan account ID milik *attacker* akan melakukan *AssumeRole* atas *role* tersebut untuk digunakan sebagai metode *persistence*.

Tentu saja terdapat juga atomic IOC yang tidak spesifik pada *cloud* yaitu *IP address*, *user agent*, dan sebagainya.

Behavioral IOC in the Cloud

Berbagai contoh behavioral IOC pada cloud environment:

Beberapa API calls berikut, merupakan TTP dari Bapak, threat actor yang diduga berasal dari Indonesia⁸.

```
['CreateCluster', 'GetSendQuota', 'GetCallerIdentity', 'DescribeInstances', 'ImportKeyPair', 'DescribeSubnets']
```

Selain rangkaian API calls tersebut, pada API calls *CreateCluster*⁹, ditemui *metadata* *clusterName* yang digunakan adalah “Bapak1”.

Defense evasion technique yang cukup sering terlihat, contohnya adalah manipulasi CloudTrail, API call yang umum terlihat adalah “StopLogging¹⁰; DeleteTrail; PutEventSelectors; DeleteDetector”. Seperti juga rangkaian *API call* dari *threat actor* Bapak, kita juga perlu melihat konteksnya. Dalam hal ini melakukan *API calls* diatas merupakan sebuah indikasi, lebih buruk lagi apabila API call tersebut datang dari lokasi yang tidak biasa.

Contoh lain adalah teknik “Backdooring AMI”.¹¹ AMI adalah *snapshot/blueprint* sebuah EC2 server. AWS memiliki beberapa AMI public atau *community AMI*. Dengan menautkan *malicious script* pada *community AMI*, maka *threat actor* berharap mendapatkan *access* ketika AMI tersebut dipakai.

Sebuah API call, tanpa konteks, tidak serta merta dapat langsung dikelompokkan sebagai *malicious*. Pada contoh diatas, kita melihat konteks melalui beberapa hal, antara lain: rangkaian API calls lain yang berkaitan erat, *cloud metadata*, ataupun indikator lain yang dapat memberikan konteks. Kita akan membahas konteks pada bagian operasionalisasi IOC selanjutnya. Beberapa contoh lain dari TTP dapat dilihat pada website wiz di

⁸ <https://www.wiz.io/blog/detecting-behavioral-cloud-indicators-of-compromise-iocs#createcluster-42>

⁹ <https://traildiscover.cloud/#ECS-CreateCluster>

¹⁰ <https://traildiscover.cloud/#CloudTrail-StopLogging>

¹¹ <https://tldrsec.com/p/blog-lesser-known-aws-attacks>

<https://threats.wiz.io/all-actors>, <https://securitylabs.datadoghq.com/cloud-security-atlas/>, atau <https://traildiscover.cloud/> (terbatas pada CloudTrail).

Mengembangkan deteksi dengan IOC



Untuk menyelami topik operasionalisasi IOC ini, kita dapat berpegangan pada *detection engineering lifecycle*, khususnya *investigate* dan *develop*. Tentu saja membahas rinci *life cycle* ini bukanlah porsi dari tulisan kilat ini¹². Penulis akan menyentuh secara umum aspek-aspek yang perlu diperhatikan Ketika kita mengembangkan deteksi dari IOC.

Konteks

Mengerti konteks dari IOC tersebut sebelum mengembangkan deteksi adalah sebuah keharusan. Contohnya apabila kita memperoleh IOC yang berupa *IP address*, maka kita perlu mengerti konteks bagaimana URL itu terkait dengan *threat actor*.

Setelah mengerti konteks dari IOC tersebut, maka kita dapat menilai katalog data yang kita miliki untuk menemukan sumber data dari deteksi kita, tentu saja dengan mempertimbangkan konteksnya. Contohnya apabila IOC yang didapat berupa *IP address*, kita dapat mencari di log web server milik kita, atau EDR telemetry, network appliances log – tentu saja sesuai dengan konteksnya.

Cost

Bagian ini terkait erat dengan pemahaman konteks. Tanpa mengerti konteks-nya maka deteksi yang dikembangkan berpotensi memiliki *cost* tinggi. Beberapa faktor biaya yang patut dipertimbangkan antara lain: biaya deteksi (*noisy/ analyst cost, compute cost*), biaya perawatan (kode deteksi yang sulit dimaintain meningkatkan biaya), *actionability* (seberapa sulit menindaklanjuti/ menganalisis lebih dalam *alert* yang dihasilkan).

Kembali ke contoh sebelumnya, IOC berupa *IP address* pada bagian sebelumnya, ternyata merupakan *IP address* pada tahapan *reconnaissance*, maka kemungkinan biaya deteksi tinggi yang disebabkan oleh *actionability* rendah (*alert low value*).

¹² buku yang penulis sertakan pada referensi membahas hal ini dengan rinci.

Performa

Performa deteksi dapat disarikan ke dalam dua sisi. *Coverage* dan *durability*. *Coverage* artinya kita seberapa luas *scope* deteksi, ini dapat dimengerti, salah satunya, melalui perbandingan dengan TTP pada MITRE.

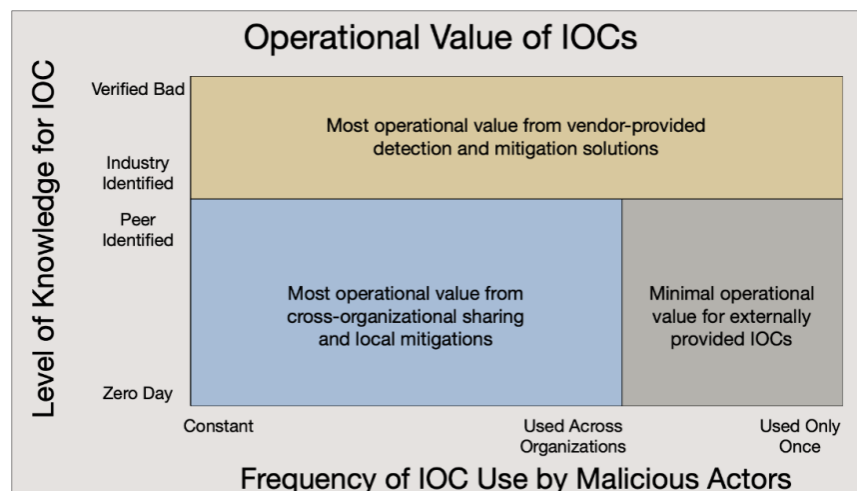
Khusus untuk operasionalisasi IOC, maka faktor *durability* menjadi lebih dominan. *Durability* dapat dijelaskan sebagai seberapa 'bandel' deteksi atas sebuah teknik.

Contohnya, deteksi atas *persistence* dengan menggunakan *cron*. Sebuah deteksi yang durable tidak hanya akan mendeteksi *command line* yang mengandung "*cron*", "*crontab -e*", tapi juga modifikasi file */etc/crontab*, dan process creation "*usr/sbin/cron*".

Mengingat kembali *pyramid of pain* pada pembahasan diatas, semakin ke atas indikator yang digunakan pada deteksi, maka deteksi tersebut akan semakin durable i.e. *cost* tinggi bagi *attacker*.

Timeliness

Hal lain yang perlu diperhatikan ketika mengembangkan deteksi dari IOC adalah *timeliness*. Berikut *quote* dan diagram dari *whitepaper* CISA¹³ untuk mensarikan dilema ini.



The right question is not if IOCs are operationally valuable, but when. A SOC gains the most operational value from expending resources to ingest and use IOC feeds when the IOCs are being reused for attacks against multiple organizations and they are shared before industry considers them malicious.

¹³ "Operational Value of Indicators of Compromise" CISA

Di sisi lain, perlu diingat bahwa terburu-buru melakukan *sharing* IOC tanpa verifikasi yang cukup, cuma akan membanjiri SOC dengan *alert*.

Timeliness, pada *white paper* CISA tersebut, juga merumuskan hubungan antara *malware lifecycle* dengan *operational value* IOC. Sebuah indikator yang terkait dengan tahap awal *malware lifecycle*, dapat memiliki *impact* yang lebih besar, dan sebaliknya. Disisi lain, IOC yang berada pada tahapan awal *malware lifecycle*, akan lebih sulit untuk diverifikasi.

Dokumentasi

Beberapa hal yang perlu disoroti terkait dengan dokumentasi adalah:

Dokumentasi dari deteksi yang kita buat, atau *metadata* dari deteksi. Hal ini terkait dengan *field* apa yang harus dimiliki oleh deteksi tersebut. *Field* yang umum digunakan antara lain: *author*, *creation/revision date*, *references*. Selain itu juga diperlukan *naming convention*, sehingga anggota tim lain dapat dengan mudah mendapat Gambaran deteksi yang kita buat.

Dokumentasi dari alert. Beberapa *field* yang umum digunakan: *alert title*, *description*, *TTP mapping*, *data sources/ index*, *action to analyze* - memuat informasi untuk menindaklanjuti alert tersebut.

Repository. Deteksi yang dibuat harus diorganisir sehingga mudah untuk di-*maintain*. Secara umum dapat dibagi ke dalam folder sesuai dengan jenis deteksi, jenis *rule* dan sebagainya.

Referensi

1. Roddie, M., Deyalsingh, J., & Katz, G. J. (2023). *Practical Threat Detection Engineering: A hands-on guide to planning, developing, and validating detection capabilities*. Packt Publishing.
2. "The Pyramid of Pain" detect-respond.blogspot.com. Accessed February 1, 2025.
<https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
3. "Intel-Driven Defense" Lockheed Martin. Accessed February 1, 2025.
<https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Intel-Driven-Defense.pdf>
4. "What are indicators of compromise (IOCs)?" Microsoft. Accessed February 1, 2025.
<https://www.microsoft.com/en-us/security/business/security-101/what-are-indicators-of-compromise-ioc>
5. "What are Indicators of Compromise (IOCs)?" Cisco. Accessed February 1, 2025.
<https://www.cisco.com/site/us/en/learn/topics/security/what-are-indicators-of-compromise-ioc.html>

6. "Understanding Indicators of Compromise (IOC) - Part I" RSA (archived). Accessed February 1, 2025.
<https://web.archive.org/web/20170914034202/https://blogs.rsa.com/understanding-indicators-of-compromise-ioc-part-i/>
7. "SES Email Service - I've been hacked" Reddit. Accessed February 5, 2025.
https://www.reddit.com/r/aws/comments/umkjin/ses_email_service_ive_been_hacked/
8. "Following Attackers' Trail in AWS" Datadog. Accessed February 5, 2025.
<https://securitylabs.datadoghq.com/articles/following-attackers-trail-in-aws-methodology-findings-in-the-wild/#most-common-enumeration-techniques>
9. "The Curious Case of DangerDev & ProtonMail.me" Invictus IR. Accessed February 10, 2025. <https://www.invictus-ir.com/news/the-curious-case-of-dangerdev-protonmail-me>
10. "Behavioral Cloud IOCs." Wiz.io. (n.d.). Accessed February 6, 2025.
<https://www.wiz.io/blog/detecting-behavioral-cloud-indicators-of-compromise-iocs>
11. "Operational Value of Indicators of Compromise" CISA. Accessed February 10, 2025.
<https://www.cisa.gov/resources-tools/resources/operational-value-indicators-compromise-white-paper>
12. "TrailDiscover." <https://traildiscover.cloud>

Tentang Penulis

Ewaldo S Hiras – Penulis adalah praktisi keamanan informasi, menulis di blog pribadi www.aldosimon.com.